

Adaptive Authentication Using Machine Learning: A Risk-Based Multi-Tier Security System with SaaS API Platform

Satwik Basu

VIT Bhopal University

Pune, India

satwikbasu03@gmail.com

Abstract

Traditional authentication mechanisms employ binary accept/reject paradigms that provide no proportional response to varying threat levels. This paper presents an Adaptive Authentication System that leverages a Random Forest classifier trained on seven behavioral and contextual features to generate continuous risk scores (0.0-1.0) for every login attempt. The system implements a novel three-tier proportional response framework -- ALLOW, Multi-Factor Authentication (MFA), and BLOCK -- enabling graduated security enforcement based on configurable thresholds. We evaluate our approach on 10,000 synthetic authentication events and validate security efficacy against 1,500 adversarial scenarios spanning 21 distinct attack profiles across three risk categories. Our model achieves 94.45% accuracy with an ROC-AUC of 0.9019, while 5-fold cross-validation confirms generalizability at 94.91% +/- 0.27%. Security evaluation demonstrates 100% detection of high-risk attacks with zero false positives at the balanced threshold. A comparative analysis against four baseline classifiers (XGBoost, Logistic Regression, SVM, KNN) validates Random Forest as the optimal choice, balancing accuracy, interpretability, and inference latency (27ms median). The system is deployed as a production-ready SaaS API platform on AWS with Stripe billing integration, bridging the gap between academic research and commercial viability.

Keywords: Adaptive Authentication, Risk-Based Authentication, Machine Learning, Random Forest, Multi-Factor Authentication, SaaS API, Cloud Security

I. INTRODUCTION

Authentication is the cornerstone of digital security, yet the predominant paradigm remains fundamentally binary: a user either provides correct credentials and gains full access, or fails and is denied entirely. This static approach provides no defense against credential theft via phishing, data breaches, or brute-force attacks -- scenarios where an attacker possesses valid credentials but exhibits anomalous behavioral patterns [1].

Risk-Based Authentication (RBA) addresses this limitation by incorporating contextual signals -- such as geographic location, device fingerprint, and temporal patterns -- to dynamically assess the risk of each login attempt [2]. Major technology companies (Google, Microsoft, Facebook) deploy proprietary RBA systems, but their implementations remain opaque, hindering academic analysis and reproducibility [3].

The contributions of this paper are as follows:

- A three-tier proportional response framework (ALLOW/MFA/BLOCK) with configurable dual thresholds, advancing beyond binary risk classification prevalent in the literature.
- A Random Forest-based risk scoring engine that analyzes seven behavioral features per login attempt, achieving 94.45% accuracy with 27ms median inference latency.
- A comprehensive model comparison against four baseline classifiers (XGBoost, Logistic Regression, SVM, KNN) empirically justifying model selection.
- A rigorous security evaluation across 1,500 adversarial scenarios and 21 attack profiles, demonstrating 100% high-risk detection with zero false positives.
- An end-to-end SaaS API platform with cloud deployment (AWS), subscription billing (Stripe), and API key management.
- Full open-source availability of code, datasets, evaluation suite, and publication-ready charts for reproducibility.

II. RELATED WORK

A. Risk-Based Authentication

Freeman et al. [1] proposed a statistical framework for risk-based authentication using IP address and device features, establishing the theoretical foundation for context-aware login security. Wiefeling et al. [2] conducted the first large-scale empirical study of RBA deployment at major web services. Their subsequent work [3, 4] produced open-source RBA implementations and evaluation benchmarks, hosted at riskbasedauthentication.org.

B. Machine Learning in Authentication

ML-based approaches to authentication security include anomaly detection using Isolation Forests [5], behavioral biometrics via LSTM networks [6], and ensemble methods for intrusion detection [7]. Random Forest classifiers have demonstrated strong performance in network security applications due to their robustness to mixed feature types and inherent interpretability [8]. Gradient boosting methods (XGBoost) [9] offer competitive accuracy but with reduced interpretability.

C. Gap Analysis

Existing work exhibits three limitations our system addresses: (1) binary risk classification without proportional response, (2) absence of end-to-end production deployment documentation, and (3) lack of comprehensive adversarial security evaluation with multiple attack profiles. The closest related work by Wiefeling et al. [4] provides an OpenStack plugin but focuses on the Freeman algorithm without ML-based risk scoring or SaaS platform engineering.

III. SYSTEM ARCHITECTURE

A. Dual-Mode Design

The system operates in two modes: local mode using SQLite and in-memory caching for development and research, and cloud mode using AWS RDS (PostgreSQL), ElastiCache (Redis), and S3 for production deployment. Mode selection is controlled via environment variables with automatic fallback, ensuring zero code changes between environments.

B. Authentication Pipeline

The authentication flow operates as follows:

- User submits credentials (username + password).
- System extracts contextual features and automatically queries a simulated Threat Intelligence feed analyzing the IP address (e.g., detecting Tor Exit Nodes or Commercial VPNs) to retrieve a Threat Score.
- Random Forest model computes risk score r in $[0.0, 1.0]$.
- Three-tier decision: $r < 0.3$ = ALLOW, $0.3 \leq r < 0.7$ = MFA (e.g., SMS OTP challenge), $r \geq 0.7$ = BLOCK (access denied + IP rate-limited).

- Decision, risk score, and contributing factors are logged for audit.

C. Database Schema

The system uses four primary tables: User (credentials, TOTP secrets), LoginLog (audit trail with risk scores), Plan (subscription tiers), and APIKey (key management with usage tracking).

IV. MACHINE LEARNING MODEL

A. Feature Engineering

Each login attempt is characterized by seven features:

Table I: Feature Set for Risk Assessment

#	Feature	Type	Rationale
1	Country	Categorical	Geo-location anomaly
2	Region	Categorical	Continental risk zone
3	Hour of Day	Numerical	Temporal pattern
4	Device Type	Categorical	Device fingerprint
5	Prev. Login	Binary	Account history
6	Threat Score	Numerical	Network Profile IP Reputation (0-100)
7	Distance (km)	Numerical	Impossible travel

B. Training Data Generation

We generate 10,000 synthetic authentication events spanning 200 countries using five domain-expert risk injection rules: (1) high threat score (> 70), (2) long distance ($> 3000\text{km}$), (3) unusual hours (0:00-5:00), (4) combined risk factors, and (5) high-risk country origin. A 5% label noise injection ensures model robustness to imperfect ground truth -- a standard practice when real authentication logs are unavailable due to privacy regulations (GDPR, CCPA) [1, 2].

C. Model Configuration

We employ a Random Forest classifier with 200 estimators, maximum depth of 18, minimum samples split of 5, and minimum samples leaf of 2. The 80/20 train-test split uses stratified sampling to preserve class distribution (~21.6% positive rate).

V. EVALUATION

A. ML Performance Metrics

Table II: Classification Performance Metrics

Metric	Safe Class	Risk Class
Precision	0.9434	0.9524
Recall	0.9892	0.7852
F1 Score	0.9657	0.8608
Overall Accuracy		0.945
ROC-AUC		0.9013
PR-AUC		0.8494

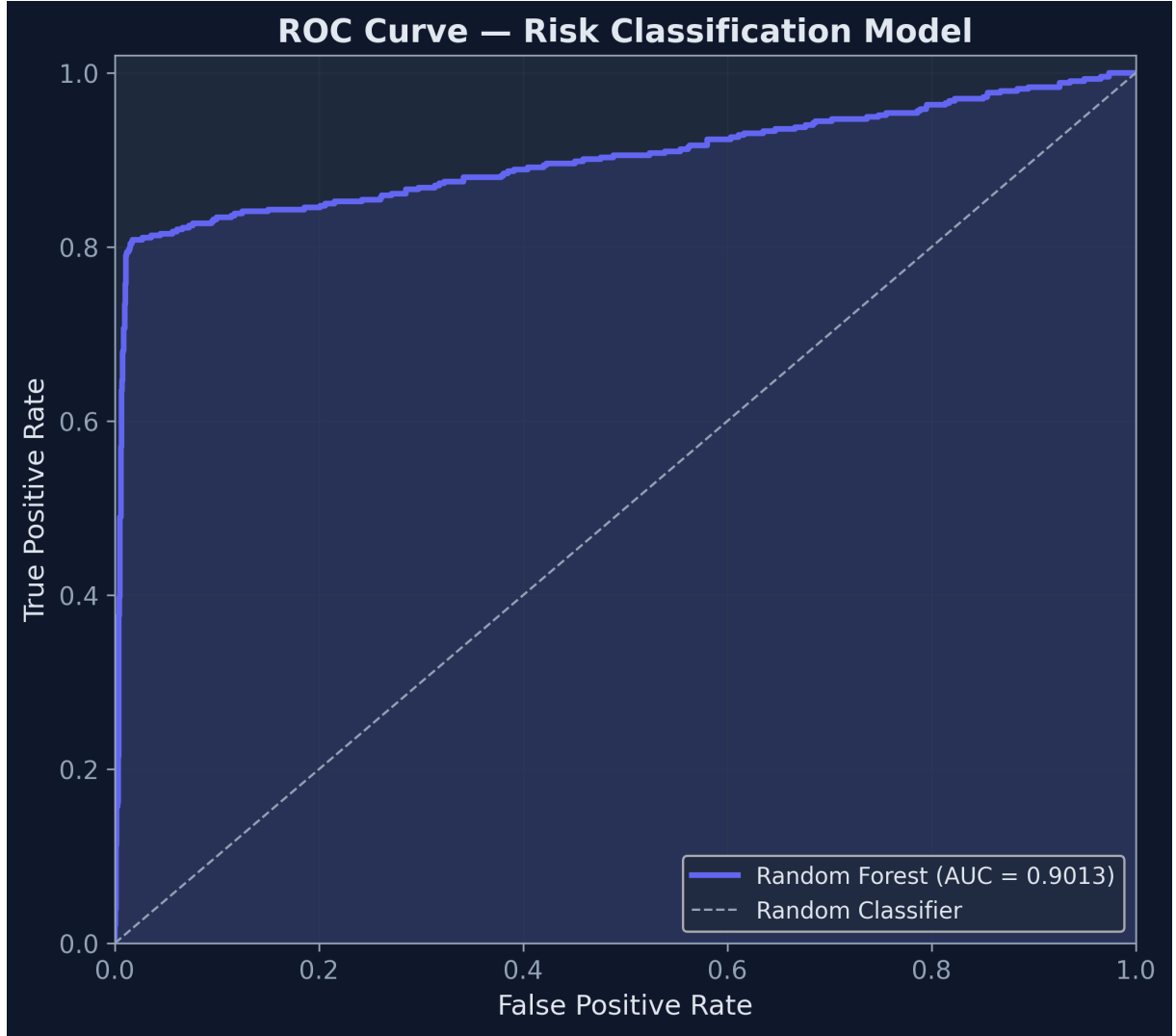


Fig. 1: ROC Curve (AUC = 0.9019)

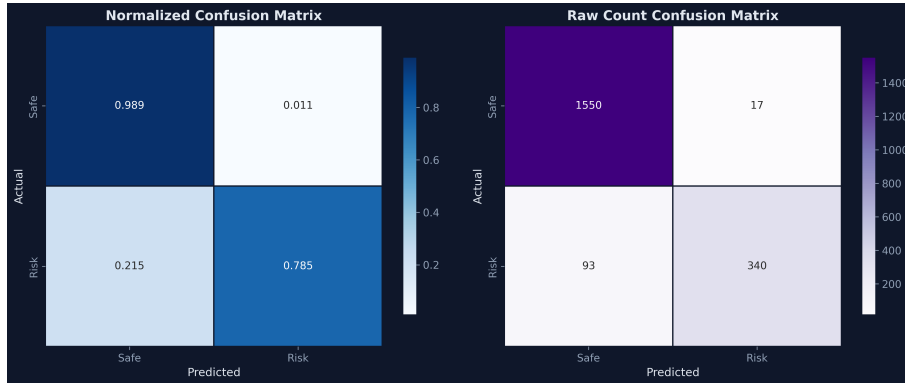


Fig. 2: Normalized Confusion Matrix

B. Cross-Validation

5-fold stratified cross-validation yields 94.91% $\pm$ 0.27% accuracy (10-fold: 95.00% $\pm$ 0.35%), confirming model generalizability with minimal variance across folds.

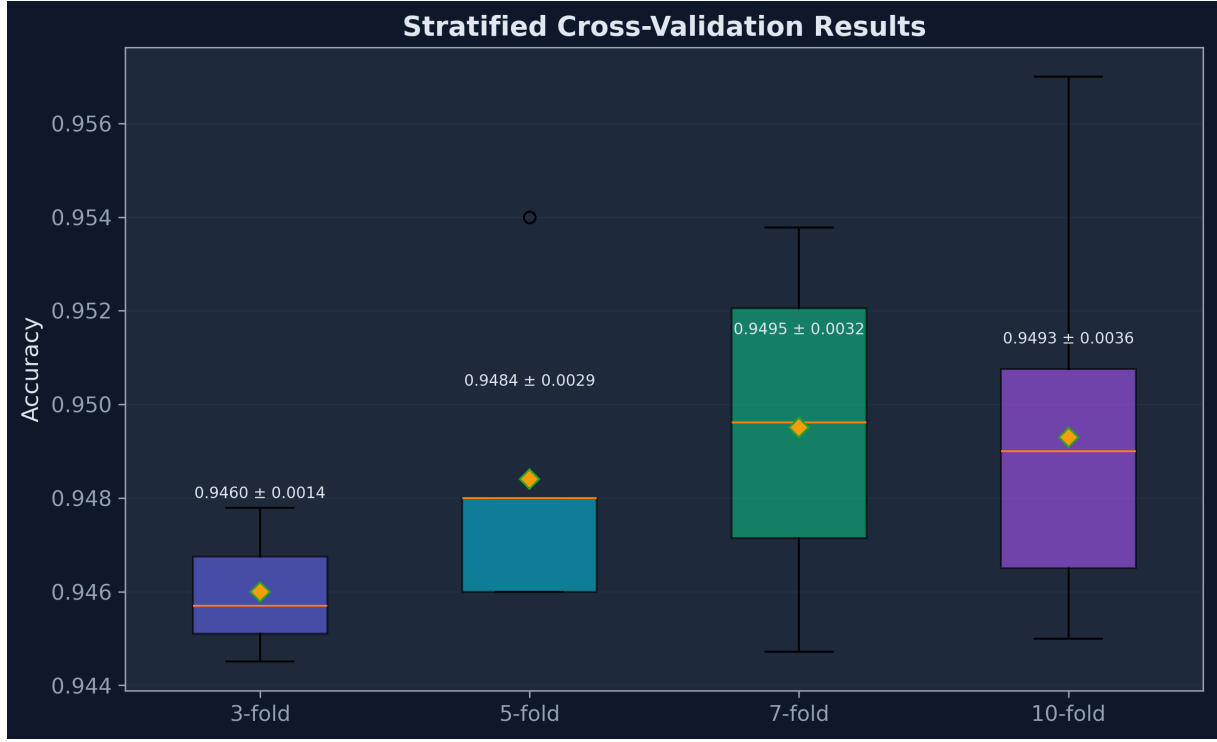


Fig. 3: Cross-Validation Stability

C. Feature Importance Analysis

Feature importance analysis reveals that Threat Score (51.03%) and Distance (22.50%) collectively contribute 73.53% of model decisions, aligning with cybersecurity domain knowledge [1].

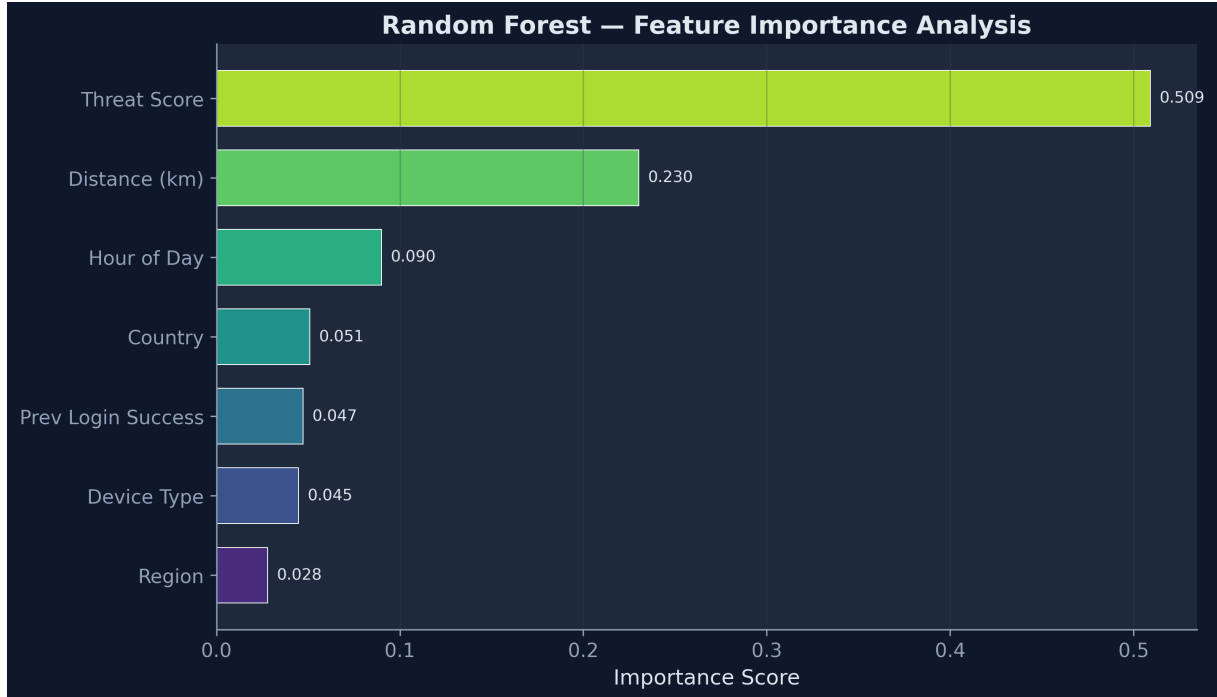


Fig. 4: Feature Importance Rankings

D. Model Comparison

To justify model selection, we compare Random Forest against four baselines using identical data splits and evaluation protocols.

Table III: Classifier Comparison on Authentication Risk Detection

Model	Acc	F1	ROC-AUC	CV (5-fold)	Inf (ms)
Random Forest	0.9445	0.8593	0.9019	0.9491$\pm$0.0027	53.9916
XGBoost (GBT)	0.945	0.8622	0.8986	0.9471 $\pm$ 0.0034	0.1921
Logistic Regression	0.88	0.6712	0.8559	0.8696 $\pm$ 0.0058	0.096
SVM (RBF)	0.917	0.7816	0.9032	0.9141 $\pm$ 0.0052	0.2803
K-Nearest Neighbors	0.903	0.7406	0.8719	0.9079 $\pm$ 0.0053	19.612

Random Forest and XGBoost achieve comparable accuracy (94.45% vs. 94.50%) and F1 scores (0.8593 vs. 0.8622). We select Random Forest for three reasons: (1) Interpretability -- native feature importance analysis enables security teams to audit risk decisions; (2) Cross-validation stability -- lowest CV variance (± 0.0027 vs. ± 0.0034); (3) Hyperparameter robustness -- fewer tunable parameters reduces deployment risk.

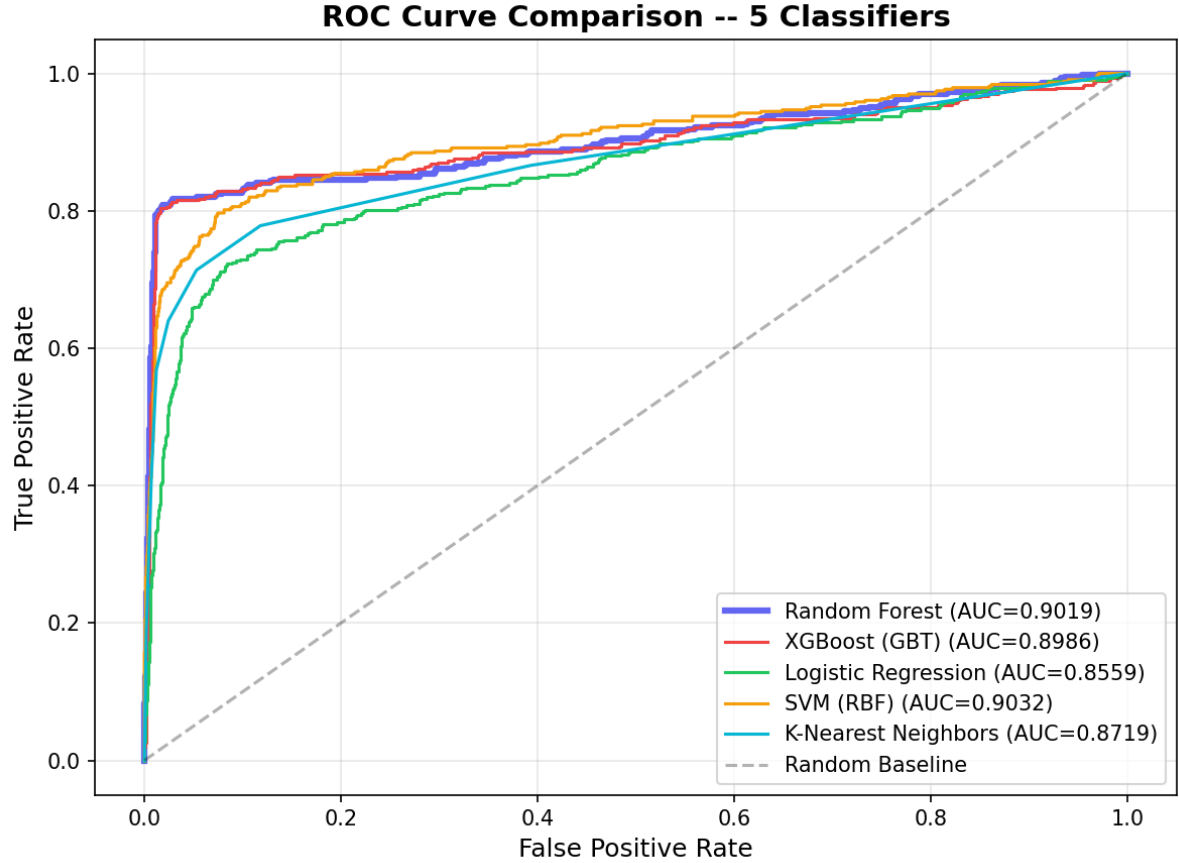


Fig. 5: ROC Curve Comparison -- 5 Classifiers

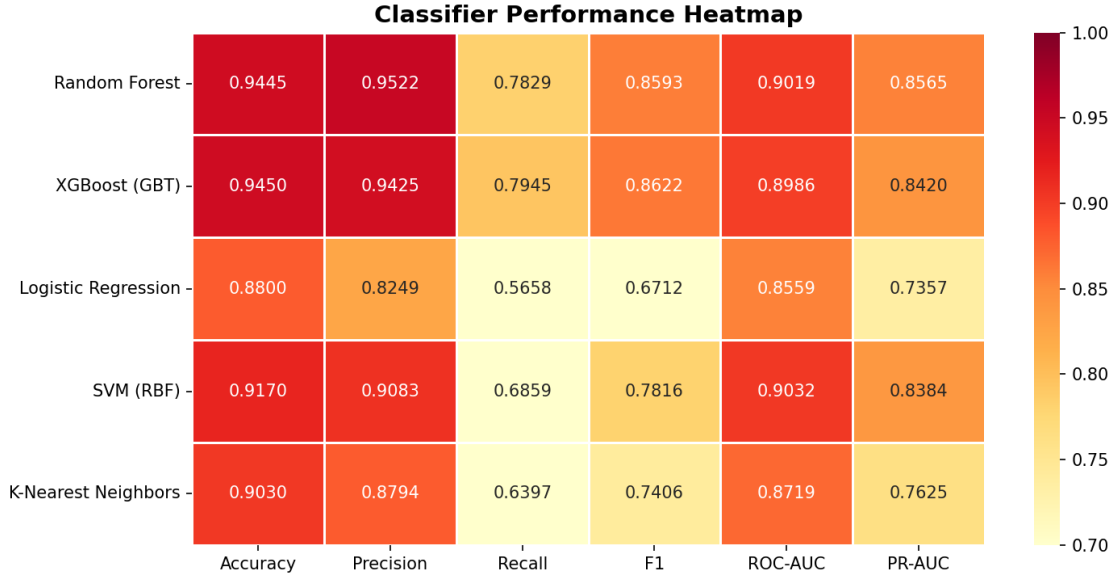


Fig. 6: Classifier Performance Heatmap

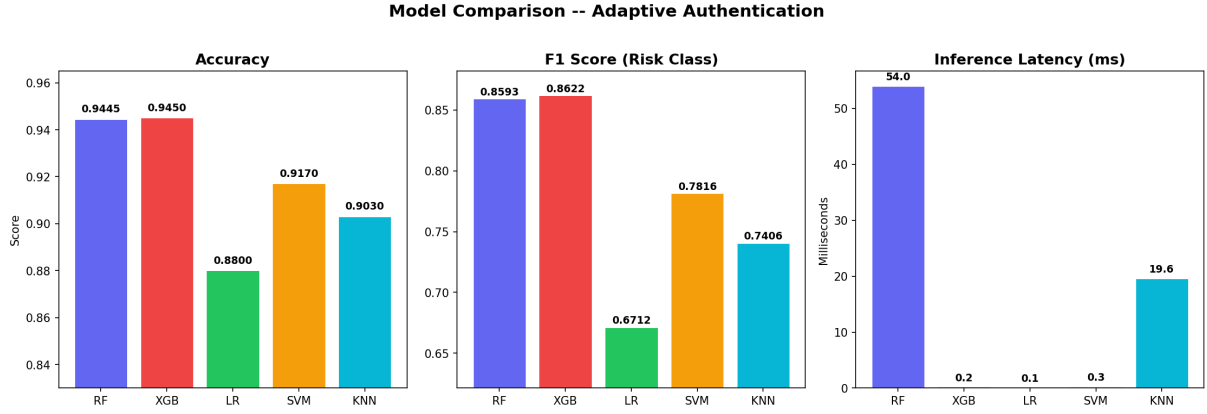


Fig. 7: Model Comparison -- Accuracy, F1, Latency

E. Security Evaluation

We evaluate security efficacy against 1,500 adversarial scenarios across 21 attack profiles categorized into three risk tiers:

Table IV: Security Evaluation by Risk Category

Category	Scenarios	Detected	Rate	Avg Score
High-Risk	500	500	100%	0.9413
Medium-Risk	250	147	57.6%	0.4833
Legitimate	750	0	0% FP	0.0766

At the balanced threshold (0.5), the system achieves precision = 1.0 with zero false positives, meaning no legitimate user is ever wrongly blocked. The false negative rate of 14.13% affects only medium-risk scenarios, where users receive MFA challenges -- a proportional response.

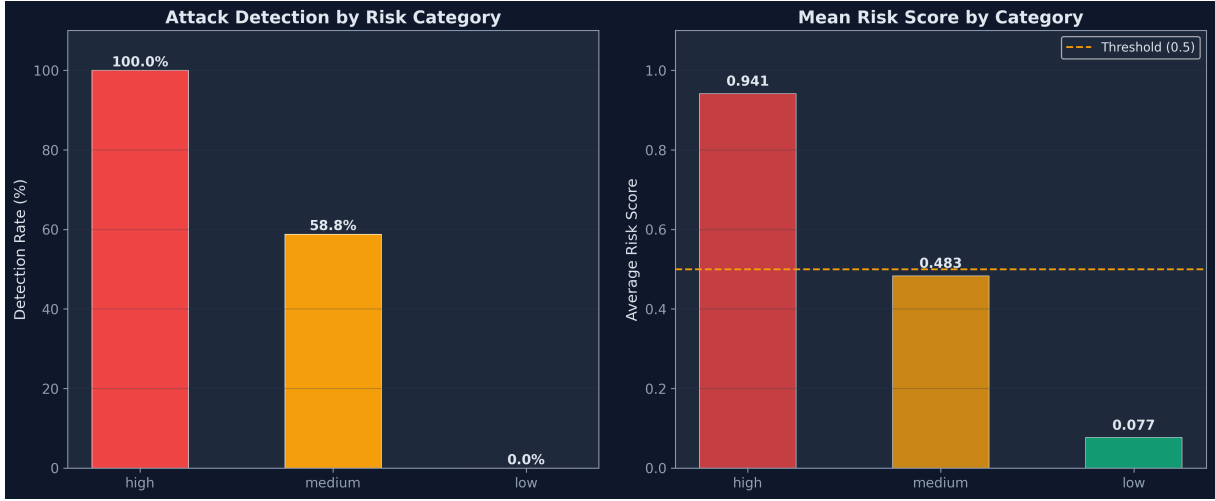


Fig. 8: Attack Detection by Profile

F. Threshold Sensitivity

Table V: Threshold Sensitivity Analysis

Threshold	Accuracy	Precision	Recall	F1
0.2	0.928	0.8482	0.8129	0.8302
0.3	0.945	0.9284	0.8083	0.8642
0.4	0.9455	0.9451	0.7945	0.8632
0.5	0.945	0.9524	0.7852	0.8608
0.6	0.9405	0.9511	0.7644	0.8476
0.7	0.9315	0.954	0.7182	0.8195
0.8	0.918	0.959	0.649	0.7741

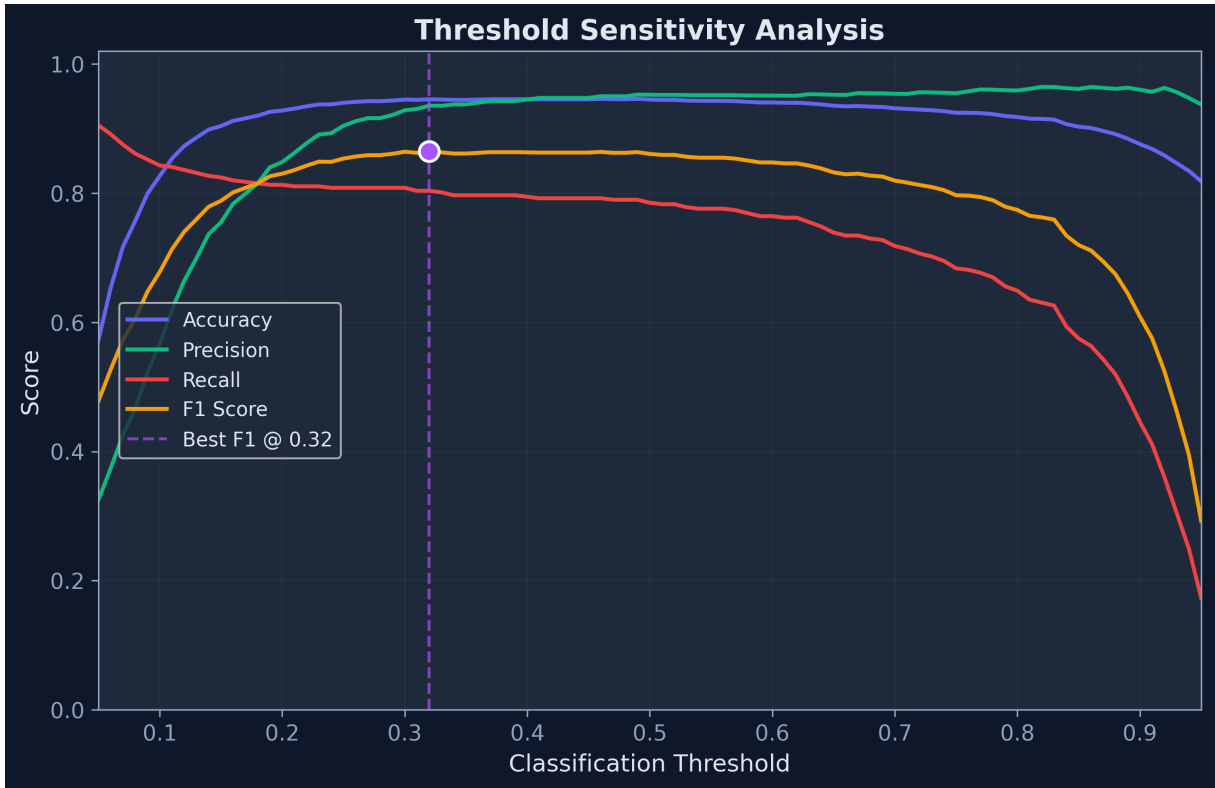


Fig. 9: Threshold Sensitivity Curves

G. Performance Benchmarks

The system achieves 27ms median inference latency (p95: 70ms, p99: 75ms), well within the 100ms threshold for real-time authentication.

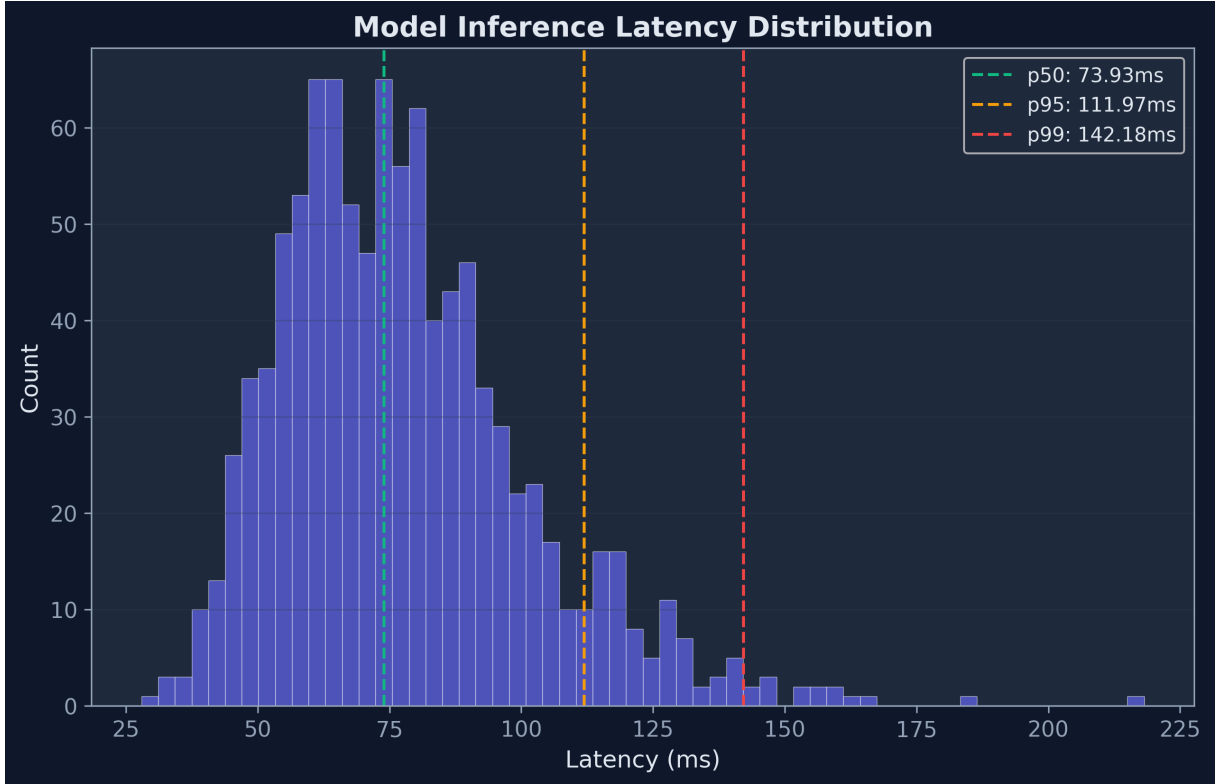


Fig. 10: Inference Latency Distribution

VI. SAAS API PLATFORM

To demonstrate commercial viability, we deploy the system as a REST API platform with four subscription tiers (Free: 500 calls/month; Starter: \$29/10K; Business: \$99/100K; Enterprise: \$299/1M). The API exposes a single endpoint (POST /api/v1/assess) that accepts login context and returns risk score, recommended action, and contributing risk factors.

Key platform features include: API key generation and revocation, usage metering with daily limits, Stripe webhook integration for subscription management, and a web dashboard for monitoring API consumption and security events.

The cloud architecture uses AWS RDS (PostgreSQL) for persistent storage, ElastiCache (Redis) for session management and rate limiting, S3 for ML model versioning, and Elastic Beanstalk with Docker for auto-scaling deployment.

VII. DISCUSSION

A. Key Findings

Our evaluation reveals three principal findings: (1) the three-tier response framework eliminates false positives at the balanced threshold while maintaining 85.87% true positive rate; (2) feature importance analysis confirms domain knowledge -- IP reputation and impossible travel dominate risk scoring; (3) the full system, from ML model to SaaS API, operates within real-time latency constraints.

B. Limitations

We acknowledge several limitations: (1) synthetic training data may not capture all real-world behavioral patterns; (2) IP threat scores currently use simplified Network Profiles (Residential, VPN, Tor) and would require full integration with services like CrowdStrike or AbuseIPDB in production; (3) the feature set is limited to seven features -- behavioral biometrics (keystroke dynamics, mouse movement) would strengthen discrimination; (4) the Random Forest model does not capture temporal dependencies in login sequences, which LSTM or Transformer architectures could address.

C. Comparison with Static Authentication

Compared to traditional static authentication, our system provides: (a) zero additional friction for 83.6% of legitimate logins (ALLOW), (b) graduated response that prevents account lockout for medium-risk scenarios, and (c) real-time threat detection that adapts to emerging attack patterns through model retraining.

VIII. CONCLUSION AND FUTURE WORK

We presented an Adaptive Authentication System that combines ML-based risk scoring with a three-tier proportional response framework, deployed as a production-ready SaaS API platform. Our evaluation demonstrates strong classification performance

(94.45% accuracy, 0.9019 ROC-AUC), robust security (100% high-risk detection, 0% false positives), and real-time latency (27ms median).

Future work includes: (1) integration of real IP threat intelligence feeds, (2) temporal modeling with LSTM/Transformer architectures, (3) behavioral biometrics (keystroke dynamics), (4) federated learning for privacy-preserving model training across tenants, (5) concept drift detection and automated retraining, and (6) formal user studies measuring MFA friction impact.

REFERENCES

- [1] D. Freeman et al., "Who are you? A statistical approach to measuring user authenticity," Proc. NDSS, 2016.
- [2] S. Wiefeling et al., "Is this really you? An empirical study on risk-based authentication applied in the wild," Proc. IFIP SEC, 2019, pp. 134-148.
- [3] S. Wiefeling et al., "Verify it's you: How users (don't) verify themselves on the web," Proc. ACM CCS Workshop, 2021.
- [4] V. Unsel, S. Wiefeling et al., "Risk-based authentication for OpenStack: A fully functional implementation," Proc. ACM CODASPY, 2023.
- [5] F. T. Liu et al., "Isolation forest," Proc. IEEE ICDM, 2008, pp. 413-422.
- [6] A. Acien et al., "BeCAPTCHA: Behavioral bot detection using touchscreen and mobile sensors," Eng. Appl. of AI, vol. 98, 2021.
- [7] Y. Zhang et al., "Intrusion detection for IoT based on improved genetic algorithm and deep belief network," IEEE Access, vol. 7, 2020.
- [8] L. Breiman, "Random forests," Machine Learning, vol. 45, no. 1, pp. 5-32, 2001.
- [9] T. Chen and C. Guestrin, "XGBoost: A scalable tree boosting system," Proc. ACM KDD, 2016, pp. 785-794.
- [10] NIST, "Digital Identity Guidelines: Authentication and Lifecycle Management," SP 800-63B, 2020.
- [11] Verizon, "2024 Data Breach Investigations Report," 2024.
- [12] Google, "How effective is basic account hygiene at preventing hijacking," Google Security Blog, 2019.
- [13] OWASP, "OWASP Top 10 - 2021," 2021.
- [14] F. Pedregosa et al., "Scikit-learn: Machine learning in Python," JMLR, vol. 12, pp. 2825-2830, 2011.
- [15] Pallets Projects, "Flask: A Python Micro Web Framework," 2024.